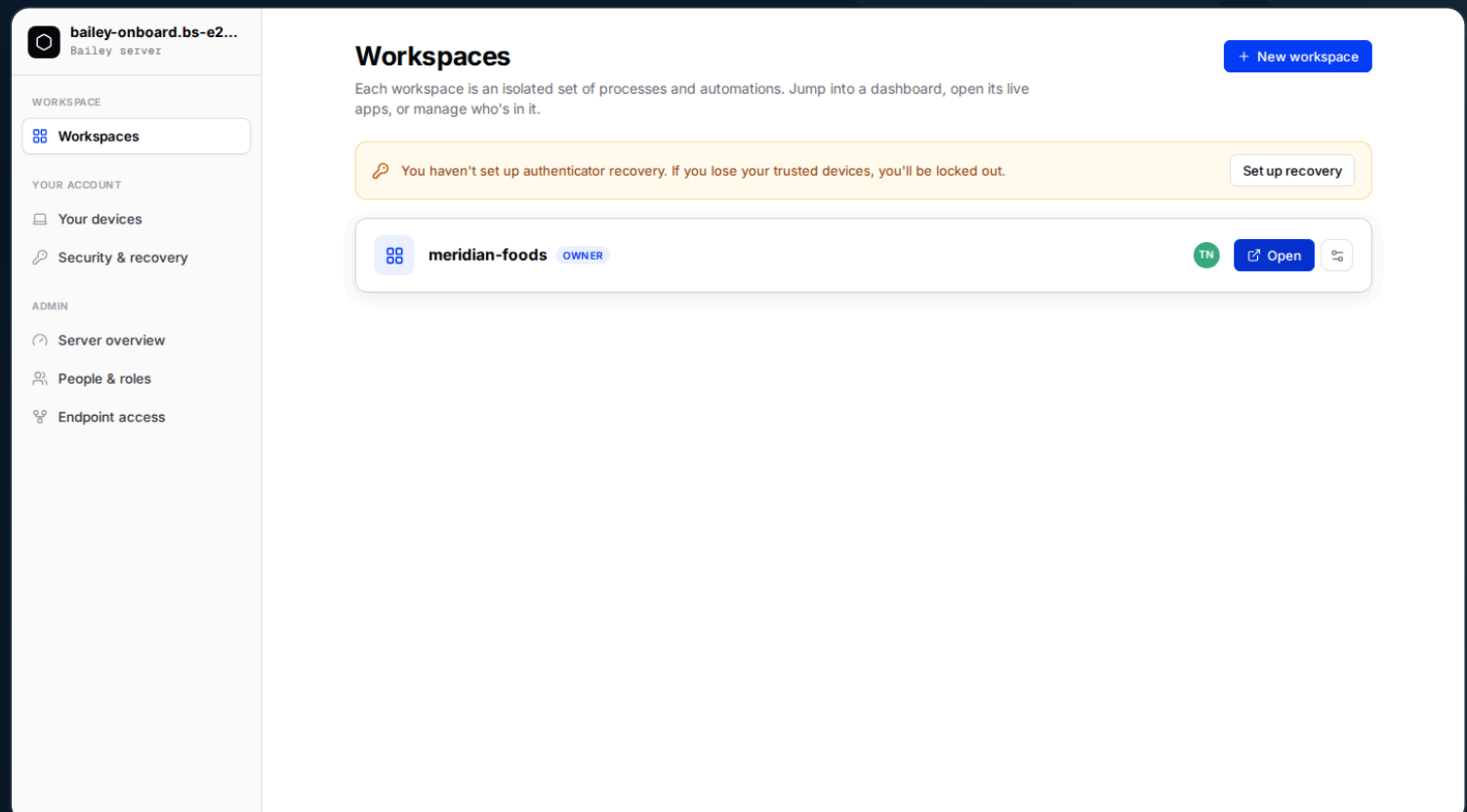


Run it like it matters.

Business processes on infrastructure that defends itself.

Blue-green production. One-click disaster-recovery rehearsals. Supply-chain scanning before anything ships. A GDPR record of processing that writes itself. Access control an auditor will actually like. This is the platform — and this manual, printed straight from a live system.

Bailey is **best practice**.



01 **Ship without holding your breath**

Promote dev → staging → production across three blue-green slots over two persistent databases. The live slot never blinks; the standby is always one cutover away.

02 **Rehearse the disaster before it happens**

Restore any production backup into an isolated DR slot, verify it by hand, mark it recovery-tested, then swap it live with a single ingress cutover. No data move. No downtime.

03 **Know what's inside before it runs**

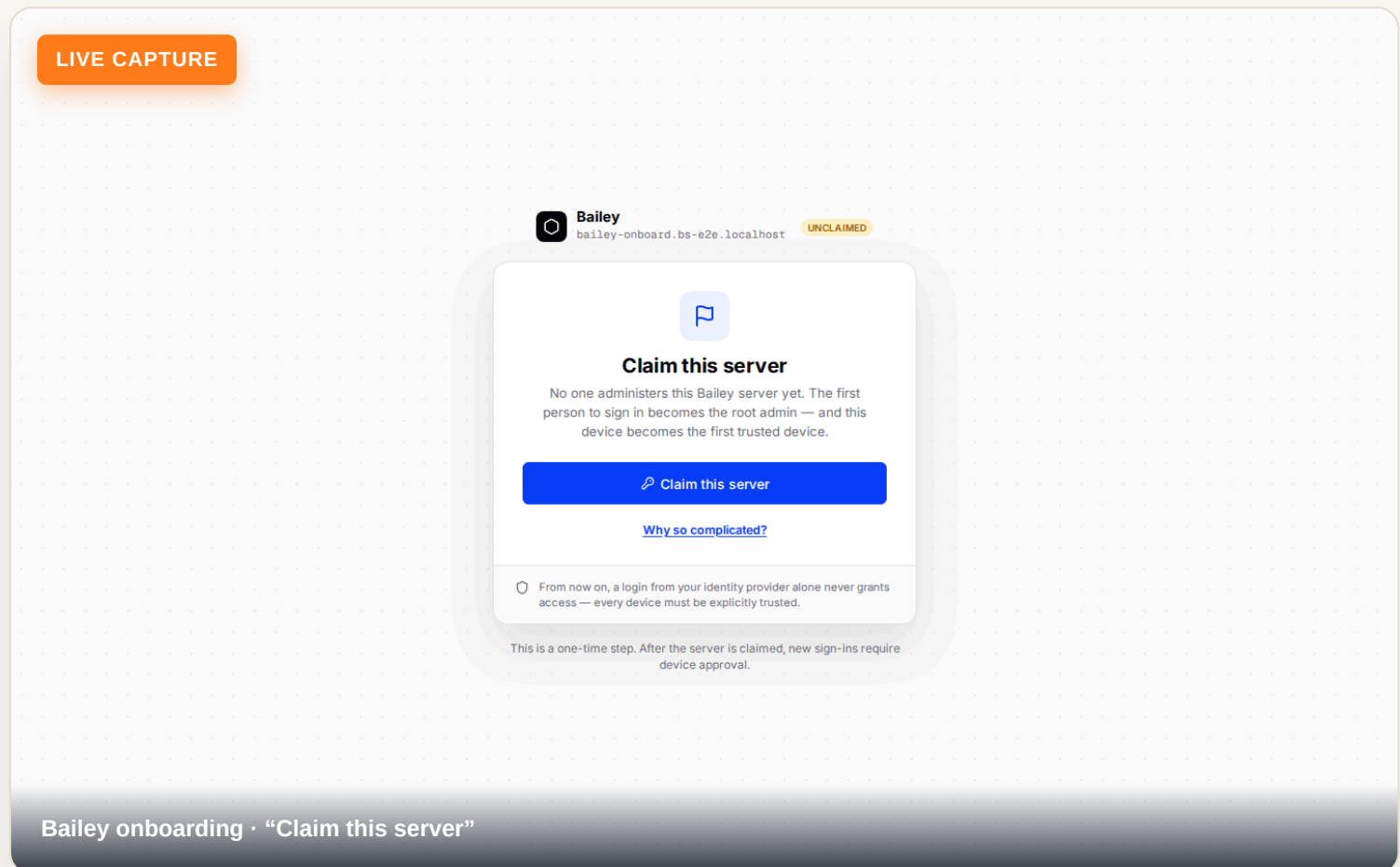
Every image is scanned for CVEs before deploy. Waivers live in your source tree, not buried in config. Auditors get a clean, signed story.

04 **Trust the device, not just the password**

The first operator claims the server; every device after is approved. Identity is enforced at the gate — your processes run safely behind it.

Claim & device trust

The first operator claims the server and becomes root admin. Their device becomes the first trusted device — and every device after is approved, not assumed.



A password that leaks shouldn't be the end of the story. Bailey binds access to **trusted devices**: Tomáš Novák signs in, claims the Meridian Foods server, and his laptop is enrolled as the first trusted device.

From then on a new device must be **approved by someone who already holds one**. The gate sits in front of everything — the console and every workspace app run behind it.

HOW TO

- 1 Sign in at the onboarding host.
- 2 Click **Claim this server** — you become root admin.
- 3 Your device is trusted; a cookie proves it.
- 4 Approve teammates' devices from **People & roles**.

WHY IT MATTERS

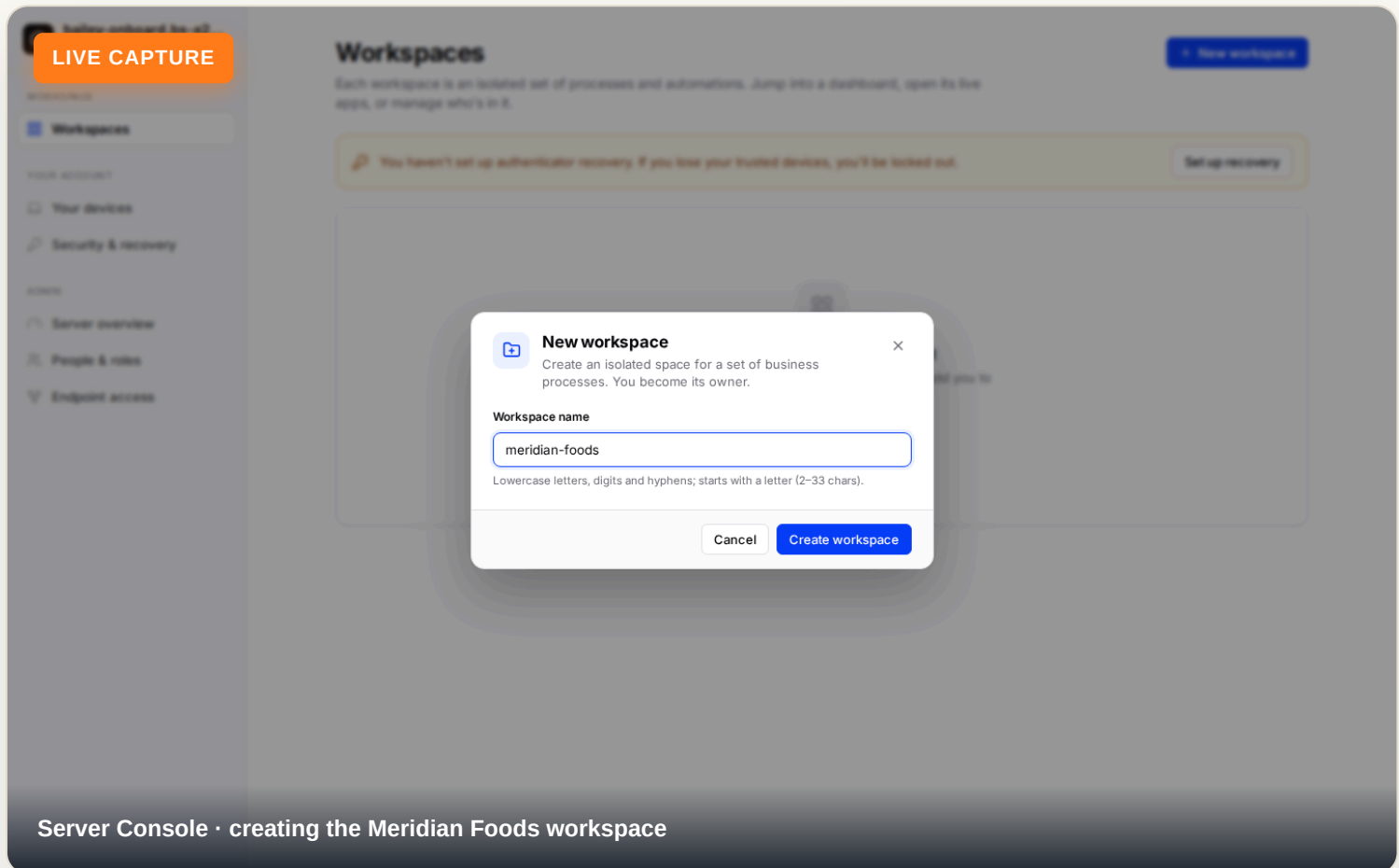
Identity is enforced once, at the gate. Your business processes never have to reinvent authentication.

 Bailey is best practice — what the standards ask of you, and how this does it

NIS2 ART. 21(2)(J)	Multi-factor authentication & secured access. Device trust is a strong second factor bound to hardware — exactly the “MFA or continuous authentication” the directive expects.
SOC 2 CC6.1	Logical access security. The gate authenticates and authorizes every request before it reaches a workspace app.
ISO/IEC 27001 A.5.15 / A.8.5	Access control & secure authentication. Access is granted per identity and per device, and centrally revocable.
DORA ART. 9(3)	Strong authentication mechanisms. Protection of ICT systems requires robust access control — the gate provides it uniformly.

Workspaces

A workspace is an isolated home for a team's business processes. Create one from the console; ownership and membership are explicit.



Server Console · creating the Meridian Foods workspace

From the Bailey Server Console, Tomáš creates the **Meridian Foods** workspace. Creation is a live, streamed operation — you watch gitops, ingress and the dashboard come up.

Each workspace is its own blast radius: separate processes, separate data, separate access. Finance's invoice flow can't reach anywhere it shouldn't.

HOW TO

- 1 Open **Workspaces** in the console.
- 2 Click **Create workspace**, name it.
- 3 Watch the live bring-up stream to done.
- 4 Open the workspace dashboard.

ISO/IEC 27001

A.8.31

Separation of development, test and production. Workspaces and stages keep environments cleanly isolated.

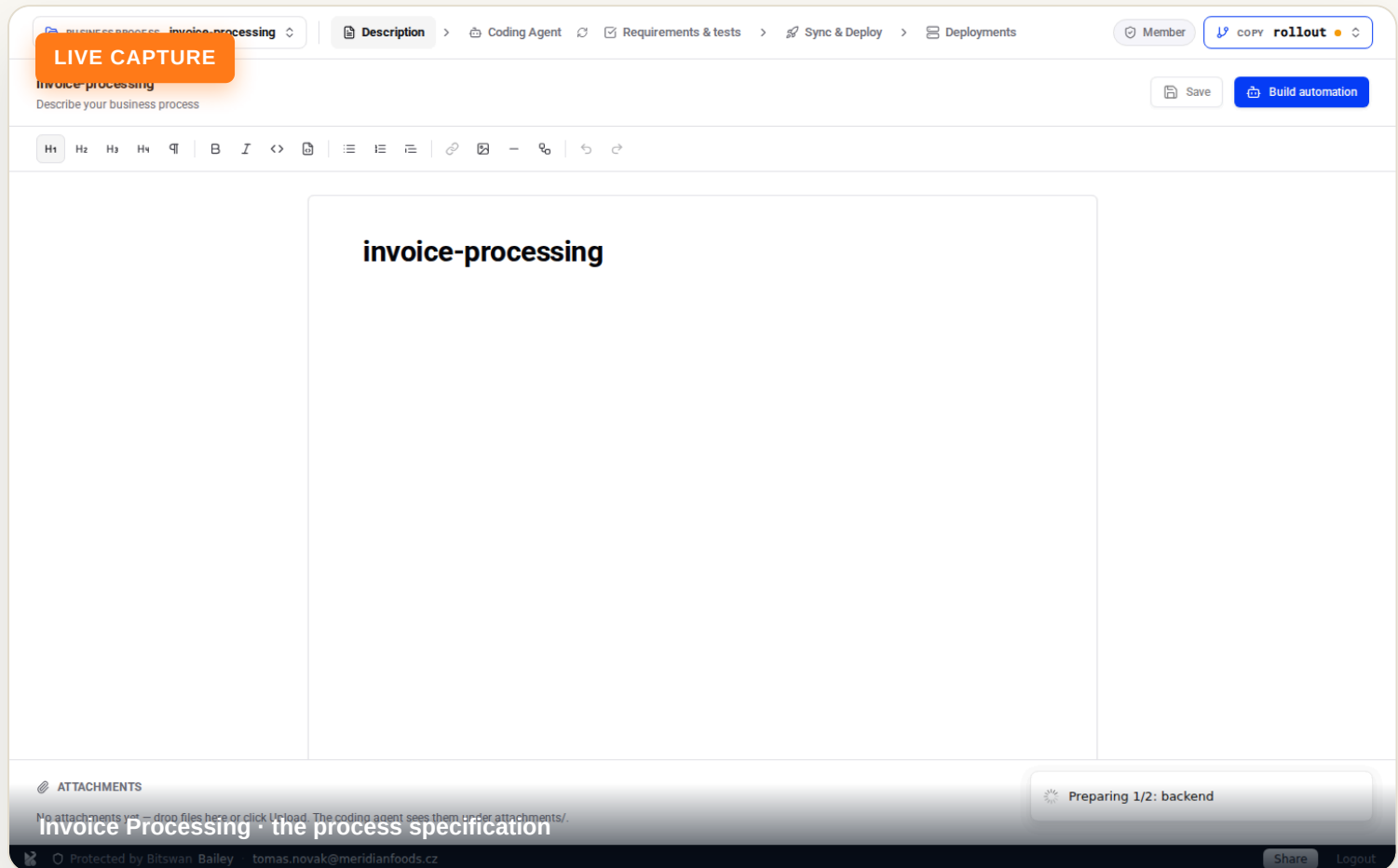
NIS2

ART. 21(2)(I)

Asset management & access control. Every workspace and its endpoints are inventoried and owned.

Describe the process

Before code, intent. Each business process carries a living specification — what it does, for whom, and the rules it must keep.



Marek documents the **Invoice Processing** spec: ingest vendor invoices, validate totals and VAT against the PO, route anything over €5,000 for approval, post the rest to the ledger.

The description is rich text with attachments and flowcharts — documentation that lives with the process, not in a wiki that drifts.

HOW TO

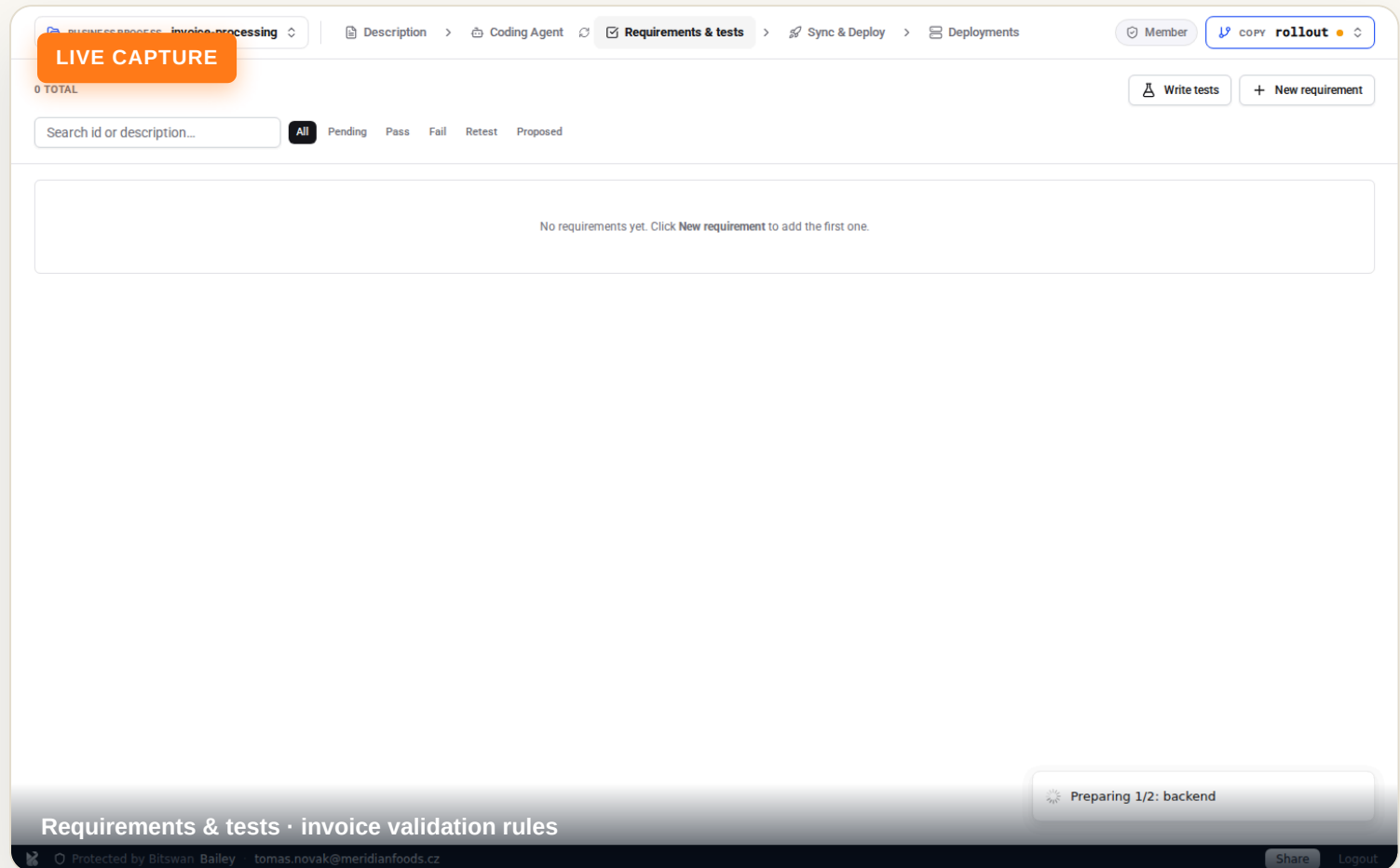
- 1 Open the **Description** tab.
- 2 Write the spec; attach diagrams.
- 3 Save — it versions with the process.



Documented operating procedures. The process and its rules are written down and kept current alongside the code.

Requirements & tests

Turn the rules into testable requirements. Each one has a status; the coding agent can run them.



Meridian's rules become checks: **VAT matches the PO, over €5,000 needs approval, no duplicate invoice numbers**. Each requirement tracks pass / fail / pending.

Testing isn't a separate ritual — it's attached to the process and visible to the auditor.

HOW TO

- 1 Open **Requirements & tests**.
- 2 Add a requirement in plain language.
- 3 Run it via the coding agent.
- 4 Watch the status badge update.



ISO/IEC 27001
A.8.29

Security testing in development and acceptance. Requirements are tested before changes are accepted.

DORA
ART. 24–25

Testing of ICT tools and systems. A maintained, runnable test suite is the basis of the resilience-testing programme.

Sync & Deploy

From a working copy to a healthy deployment — with a security check standing between you and production.

The screenshot shows the 'Sync & Deploy' interface. At the top, there's a navigation bar with tabs for 'Description', 'Coding Agent', 'Requirements & tests', 'Sync & Deploy' (active), and 'Deployments'. A 'LIVE CAPTURE' badge is visible. Below the navigation, the 'Sync & Deploy' section shows a message: 'Rebases **rollout** onto the **main code area**, then builds and deploys every container in this business process to **dev**. Your changes below become the new main once the deploy succeeds.' It also shows 'THIS BUSINESS PROCESS' with '1 ahead', '37 uncommitted files', '+1883', and '-0'. A 'Sync & Deploy' button is on the right. Below this, the 'Diff' tab is active, showing a list of 37 files with a total of +1883 changes. The files listed include 'invoice-processing/README.md', 'invoice-processing/backend/auth.go', 'voice-processing/backend/automation.toml', 'invoice-processing/backend/db.go', 'invoice-processing/backend/go.mod', 'invoice-processing/backend/go.sum', 'invoice-processing/backend/handlers_internal.go', 'voice-processing/backend/handlers_public.go', 'voice-processing/backend/image/Dockerfile', 'invoice-processing/backend/image/air.toml', and 'voice-processing/backend/image/entrypoint.sh'. A 'Sync & Deploy · ready to ship to development' banner is at the bottom. A status bar at the very bottom shows 'Protected by BitSwan Bailey' and 'tomas.novak@meridianfoods.cz'. A 'Share' button and 'Logout' link are also present.

One button does the careful thing: commit work-in-progress, rebase onto main, fast-forward, roll out to development — **tracking the single deploy it started** instead of racing a second one.

Before you promote, the **Checks** tab shows the exact CVEs of the image this deploy *would* build. Click any CVE for its advisory; mark what's out of scope — into your source tree, where review can see it.

HOW TO

- 1 Open **Sync & Deploy**.
- 2 Review the **diff** and the **Checks** tab.
- 3 Press **Sync & Deploy** — dev goes **Healthy**.
- 4 Promote when you're ready.

The check happens on the image that will actually run — not last week’s scan. Security is a step in the flow, not a gate someone forgets.

Business Process - invoice-processing

Description > Coding Agent > Requirements & tests > Sync & Deploy > Deployments

Member

COPY rollout

LIVE CAPTURE

Sync & Deploy

Rebases rollout onto the main code area, then builds and deploys every container in this business process to dev. Your changes below become the new main once the deploy succeeds.

THIS BUSINESS PROCESS ↑ 1 ahead 37 uncommitted files +1883 -0

Sync & Deploy

Diff

History

Checks

No buildable automation source found for invoice-processing in rollout.

Starting containers...

Checks tab · CVEs of the image this deploy would build

Protected by Bitswan Bailey tomas.novak@meridianfoods.cz

Share Logout

Bailey is best practice — what the standards ask of you, and how this does it	
ISO/IEC 27001 A.8.8	Management of technical vulnerabilities. The image is CVE-scanned before it ships, with each finding linked to its advisory.
NIS2 ART. 21(2)(E)	Security in acquisition, development and maintenance, incl. vulnerability handling. Waivers are versioned in-tree and reviewable.
DORA ART. 8–9	ICT risk identification & protection. Pre-deploy scanning makes risk identification automatic and auditable.

Supply chain

A full software bill of materials for what you run — vulnerabilities ranked, accepted risks recorded.

LIVE CAPTURE



Supply chain · SBOM with CVE severity rollup

Every deployed image carries an SBOM. The Supply chain view ranks vulnerabilities by severity and shows the affected package, with links to osv.dev, NVD and GitHub advisories.

Out-of-scope decisions are explicit, attributable and stored in source — not a screenshot in someone's inbox.

HOW TO

- 1 Open a stage → **Supply chain**.
- 2 Sort by severity; open a CVE.
- 3 Record any out-of-scope decision.



Bailey is best practice — what the standards ask of you, and how this does it

NIS2
ART. 21(2)(D)

Supply-chain security. You can produce, on demand, exactly what is inside what you run.

SOC 2
CC7.1

Vulnerability detection. The SBOM and CVE scan run on the image that actually ships.

ISO/IEC 27001
A.5.7 / A.8.8

Threat intelligence & vulnerability management. Continuous visibility of known vulnerabilities in your dependencies.

Blue-green production

Three app slots over two persistent databases. The live slot owns production; the standby owns DR; the third is your zero-downtime buffer.

LIVE CAPTURE



Deployments · Production healthy after promote

Promote dev → staging → production and the idle slot comes up on the live database, ingress repoints, the old slot retires. Users never see a gap.

Production is a state you can read at a glance: which slot is live, which is standby, what's healthy.

HOW TO

- 1 Open **Deployments** → **Development**.
- 2 Press **Promote** to staging, then production.
- 3 Confirm Production is **Healthy**.

3 slots

2 DBs

0 s

 Bailey is best practice — what the standards ask of you, and how this does it

ISO/IEC 27001
A.8.32

Change management. Production changes follow a controlled, reversible promotion path.

DORA
ART. 9

Protection & prevention. Minimise the impact of changes on the availability of critical functions.

Secrets

Per-stage environment secrets, write-gated by role and snapshotted with every deployment.

LIVE CAPTURE



Production · environment secrets, role-gated

The payment-gateway credentials and the approval threshold live as stage secrets. Members read; admins and auditors write. Every deployment captures the secret set in force at that moment.

No secrets in the repo, no secrets in a chat thread.

HOW TO

- 1 Open a stage → **Secrets**.
- 2 Add keys (gateway id, threshold...).
- 3 They're injected at deploy, never committed.



ISO/IEC 27001
A.8.24

Use of cryptography & secret management. Secrets are stored and injected securely, separated from source.

NIS2
ART. 21(2)(H)

Cryptography and, where appropriate, encryption. Sensitive material is handled as such by default.

Backups & retention

Point-in-time snapshots of the live database and object storage, with a retention policy and an audit trail.

LIVE CAPTURE



Production · snapshot captured from the live DB

A snapshot captures the **live blue-green database** — not a stale name — plus object storage. Retention is a policy, not a cron job someone half-remembers.

Backups you can see, size, restore and clone between stages.

HOW TO

- 1 Open **Production** → **Backups**.
- 2 Press **Create snapshot**.
- 3 See it listed with size and contents.
- 4 Set the retention policy.



ISO/IEC 27001
A.8.13

Information backup. Backups are taken, retained and verifiable by restoration.

DORA
ART. 12(1)

Backup policies and procedures. Scope and frequency are defined and enforced.

Rehearse & restore

A backup you've never restored is a rumor. Bitswan makes the rehearsal a routine — and the real thing a single swap.

LIVE CAPTURE



Disaster Recovery · backup loaded into DR, recovery-tested

Restore a production backup **into the DR slot** — never onto live production. Open it, confirm it's whole. Only the backup actually loaded into DR can be **marked recovery-tested**.

When you must go live, the **Restore** pill performs an ingress cutover: -production repoints to the verified slot. No data migration, no redeploy, no downtime.

HOW TO

- 1 Take a production snapshot.
- 2 Go to **Disaster Recovery** → **Rehearse & restore**.
- 3 **Restore into DR**, verify, **Mark recovery-tested**.
- 4 Use the **Restore** pill to swap live when needed.

0 s

downtime on a swap

Quarterly

default test cadence

Verified

test only what's loaded

 Bailey is best practice — what the standards ask of you, and how this does it

DORA
ART. 11–12

Response, recovery & restoration testing. You must regularly test your ability to restore — here it's a routine, and the last pass is recorded.

SOC 2
A1.2 / A1.3

Backup & recovery testing. Restores are rehearsed into an isolated DR slot and the test is recorded.

ISO/IEC 27001
A.5.30 / A.8.13

ICT readiness for continuity. Backups are verified by restoration into an isolated slot.

NIS2
ART. 21(2)(C)

Business continuity & crisis management. A zero-downtime swap means recovery doesn't cost an outage.

Deployment history

A versioned, immutable audit log: every deploy, promotion, swap, backup and firewall change — with the diff and the secrets in force at the time.

LIVE CAPTURE



Deployment history · the audit trail

Who shipped what, when, on which commit, and what changed — including backup, restore, swap and retention events. Inspect any entry for its files, diff and secret snapshot.

When an auditor asks “show me”, you open a tab.

HOW TO

- 1 Open a stage → **History**.
- 2 Read the timeline of events.
- 3 Inspect an entry for diff and secrets.



Bailey is best practice — what the standards ask of you, and how this does it

DORA

ART. 13

Learning and evolving. A complete record supports post-incident review.

NIS2

ART. 21(2)(B)

Incident handling. Reconstruct exactly what happened from the audit trail.

Firewall & data processing

An egress allow-list with a GDPR data-processing record for every external host — approval workflow, versioning and the DPA on file.

LIVE CAPTURE



Firewall · egress allow-list with GDPR records

Meridian's invoice flow may reach its vendor portals, the Czech business register and a payment gateway — and nothing else. Each allowed host carries a **GDPR data-processing record**: the purpose, whether personal data flows to that recipient, and the signed **Data Processing Agreement** on file.

Egress is default-deny. A new destination can't go live until someone completes its processing record — so your Article 30 register builds itself as the system is operated, instead of being reconstructed under audit pressure.

HOW TO

- 1 Open a stage → **Firewall**.
- 2 Review hosts waiting for approval.
- 3 Complete the **GDPR data-processing record** (purpose, personal data, lawful basis).
- 4 Attach the processor's **DPA** and approve — the host is recorded and allowed.

GDPR, BY CONSTRUCTION

Every external recipient of data is recorded with its purpose and contract at the moment it's allowed. The record of processing activities (Art. 30) and the processor agreements (Art. 28) are a by-product of running the system — not a spreadsheet someone keeps separately.

 Bailey is best practice — what the standards ask of you, and how this does it

GDPR ART. 30	Records of processing activities. Each external recipient is logged with its purpose and whether personal data is transferred — the register maintained automatically.
GDPR ART. 28	Processor obligations. A Data Processing Agreement is stored on file for every host that processes personal data before egress is allowed.
NIS2 ART. 21(2)(A)	Risk-analysis & network security policies. Default-deny egress with reviewed, documented exceptions.
ISO/IEC 27001 A.8.20–8.21	Network & network-service security. Outbound connections are controlled per service.

People & roles

A roster with explicit roles — operator, auditor, member — and per-person trusted devices you can approve or revoke.

bailey-onboard bs-e2
LIVE CAPTURE

WORKSPACE
Workspaces

YOUR ACCOUNT
Your devices
Security & recovery

ADMIN
Server overview
People & roles
Endpoint access

People & roles

Everyone with access to this server. Roles govern what they can do; devices govern where they can do it from. New sign-ins from an untrusted device appear here for you to approve.

☐ Least-trust access: a role grants *capabilities*, never blanket data access. Even an admin only reaches workspaces they created or were granted — so each person controls who sees their own data.

ADMIN Manages users, server settings, and device approvals. Still sees only workspaces they own or were granted — not everyone's.

AUDITOR Reviews security activity and signs off on deploy promotions. No automatic access to others' workspace data.

MEMBER Builds in workspaces they own or were added to.

USER A signed-in identity with no elevated role; sees only workspaces they own or are added to.

Search people...

PERSON	ROLE	WORKSPACES	DEVICES	LAST ACTIVE
tomas.novak@meridianfoods.cz tomas.novak@meridianfoods.cz	ADMIN	1	1	6/20/2026, 10:00:53 PM

People & roles · the Meridian Foods roster

Tomáš operates, Eva audits (read-only oversight, sets the recovery cadence), Marek and the team build. Roles are enforced server-side, not just hidden in the UI.

Each person's devices are visible; approve a new laptop, revoke a lost one — instantly, everywhere.

HOW TO

- 1 Open **People & roles** in the console.
- 2 Review roles across the team.
- 3 Approve or revoke devices per person.



ISO/IEC 27001 A.5.18 / A.5.3	Access rights & segregation of duties. Operator, auditor and member are distinct roles with least privilege.
SOC 2 CC6.2 / CC6.3	Access provisioning & de-provisioning. Roles and per-person trusted devices are granted and revoked centrally.
NIS2 ART. 21(2)(I)	Human-resources security & access control. Access is role-based and reviewable.
DORA ART. 9(4)	Access management on a need-to-know basis. Auditors get oversight without write power.

Standards → features

One page for your auditor: the controls ISO 27001, SOC 2, DORA, NIS2 and GDPR ask for, and the Bitswan feature that delivers each.

STANDARD & CLAUSE	WHAT IT ASKS OF YOU	DELIVERED BY
NIS2 Art. 21(2)(j)	Multi-factor authentication & secured access. Device trust is a strong second factor bound to hardware — exactly the “MFA or continuous authentication” the directive expects.	Claim & device trust
SOC 2 CC6.1	Logical access security. The gate authenticates and authorizes every request before it reaches a workspace app.	Claim & device trust
ISO/IEC 27001 A.5.15 / A.8.5	Access control & secure authentication. Access is granted per identity and per device, and centrally revocable.	Claim & device trust
DORA Art. 9(3)	Strong authentication mechanisms. Protection of ICT systems requires robust access control — the gate provides it uniformly.	Claim & device trust
ISO/IEC 27001 A.8.31	Separation of development, test and production. Workspaces and stages keep environments cleanly isolated.	Workspaces
NIS2 Art. 21(2)(i)	Asset management & access control. Every workspace and its endpoints are inventoried and owned.	Workspaces
ISO/IEC 27001 A.5.37	Documented operating procedures. The process and its rules are written down and kept current alongside the code.	Describe the process
ISO/IEC 27001 A.8.29	Security testing in development and acceptance. Requirements are tested before changes are accepted.	Requirements & tests
DORA Art. 24–25	Testing of ICT tools and systems. A maintained, runnable test suite is the basis of the resilience-testing programme.	Requirements & tests
ISO/IEC 27001 A.8.8	Management of technical vulnerabilities. The image is CVE-scanned before it ships, with each finding linked to its advisory.	Sync & Deploy
NIS2 Art. 21(2)(e)	Security in acquisition, development and maintenance, incl. vulnerability handling. Waivers are versioned in-tree and reviewable.	Sync & Deploy

STANDARD & CLAUSE	WHAT IT ASKS OF YOU	DELIVERED BY
DORA Art. 8–9	ICT risk identification & protection. Pre-deploy scanning makes risk identification automatic and auditable.	Sync & Deploy
NIS2 Art. 21(2)(d)	Supply-chain security. You can produce, on demand, exactly what is inside what you run.	Supply chain
SOC 2 CC7.1	Vulnerability detection. The SBOM and CVE scan run on the image that actually ships.	Supply chain
ISO/IEC 27001 A.5.7 / A.8.8	Threat intelligence & vulnerability management. Continuous visibility of known vulnerabilities in your dependencies.	Supply chain
ISO/IEC 27001 A.8.32	Change management. Production changes follow a controlled, reversible promotion path.	Blue-green production
DORA Art. 9	Protection & prevention. Minimise the impact of changes on the availability of critical functions.	Blue-green production
ISO/IEC 27001 A.8.24	Use of cryptography & secret management. Secrets are stored and injected securely, separated from source.	Secrets
NIS2 Art. 21(2)(h)	Cryptography and, where appropriate, encryption. Sensitive material is handled as such by default.	Secrets
ISO/IEC 27001 A.8.13	Information backup. Backups are taken, retained and verifiable by restoration.	Backups & retention
DORA Art. 12(1)	Backup policies and procedures. Scope and frequency are defined and enforced.	Backups & retention
DORA Art. 11–12	Response, recovery & restoration testing. You must regularly test your ability to restore — here it's a routine, and the last pass is recorded.	Rehearse & restore
SOC 2 A1.2 / A1.3	Backup & recovery testing. Restores are rehearsed into an isolated DR slot and the test is recorded.	Rehearse & restore
ISO/IEC 27001 A.5.30 / A.8.13	ICT readiness for continuity. Backups are verified by restoration into an isolated slot.	Rehearse & restore
NIS2 Art. 21(2)(c)	Business continuity & crisis management. A zero-downtime swap means recovery doesn't cost an outage.	Rehearse & restore
ISO/IEC 27001 A.8.15	Logging. Operational events are recorded and protected from tampering.	Deployment history

STANDARD & CLAUSE	WHAT IT ASKS OF YOU	DELIVERED BY
DORA Art. 13	Learning and evolving. A complete record supports post-incident review.	Deployment history
NIS2 Art. 21(2)(b)	Incident handling. Reconstruct exactly what happened from the audit trail.	Deployment history
GDPR Art. 30	Records of processing activities. Each external recipient is logged with its purpose and whether personal data is transferred — the register maintained automatically.	Firewall & data processing
GDPR Art. 28	Processor obligations. A Data Processing Agreement is stored on file for every host that processes personal data before egress is allowed.	Firewall & data processing
NIS2 Art. 21(2)(a)	Risk-analysis & network security policies. Default-deny egress with reviewed, documented exceptions.	Firewall & data processing
ISO/IEC 27001 A.8.20–8.21	Network & network-service security. Outbound connections are controlled per service.	Firewall & data processing
ISO/IEC 27001 A.5.18 / A.5.3	Access rights & segregation of duties. Operator, auditor and member are distinct roles with least privilege.	People & roles
SOC 2 CC6.2 / CC6.3	Access provisioning & de-provisioning. Roles and per-person trusted devices are granted and revoked centrally.	People & roles
NIS2 Art. 21(2)(i)	Human-resources security & access control. Access is role-based and reviewable.	People & roles
DORA Art. 9(4)	Access management on a need-to-know basis. Auditors get oversight without write power.	People & roles

What Bailey gives you — at a glance

For each standard, how many technical controls Bailey provides outright, supports in part, or leaves to you to operate. The pages that follow break each down control-by-control, with a pointer to the chapter that shows it working.

ISO/IEC 27001:2022	9 PROVIDED	2 PARTIAL	0 YOUR PART
SOC 2 (Trust Services Criteria)	7 PROVIDED	2 PARTIAL	0 YOUR PART
DORA (Regulation (EU) 2022/2554)	6 PROVIDED	2 PARTIAL	0 YOUR PART
NIS2 (Directive (EU) 2022/2555)	6 PROVIDED	2 PARTIAL	0 YOUR PART
GDPR (Regulation (EU) 2016/679)	4 PROVIDED	1 PARTIAL	0 YOUR PART

✓ Provided

delivered by the platform

▸ Partial

platform supports it; you complete it

○ Your part

your organization operates it

ISO/IEC 27001:2022

Annex A technical controls. Bailey implements the platform-side controls below; the management-system controls (policies, risk assessment, HR, physical) remain yours.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
A.5.15 / A.8.5	Access control & secure authentication	✓ Provided	Device-trust gate + OIDC at the platform edge	Your IdP, joiner/leaver process	01
A.5.18	Access rights (least privilege, review)	✓ Provided	Operator / auditor / member roles, server-enforced	Periodic access reviews	13
A.8.8	Management of technical vulnerabilities	✓ Provided	Pre-deploy CVE scan + in-tree waivers	Triage & remediation SLAs	05 · 06
A.8.9	Configuration management	▸ Partial	bitswan.yaml as declarative source of truth	Baseline definition & review	07
A.8.13	Information backup	✓ Provided	Per-stage snapshots + retention policy	Offsite copy & retention targets	09
A.8.15 / A.8.16	Logging & monitoring	▸ Partial	Versioned deployment & event history	SIEM aggregation, alerting	11
A.8.20 / A.8.21	Network & network-services security	✓ Provided	Default-deny egress allow-list per service	Perimeter & internal segmentation policy	12
A.8.24	Use of cryptography & secrets	✓ Provided	Stage secrets, injected not committed; TLS at edge	Key-management policy	08
A.8.31	Separation of dev/test/production	✓ Provided	Isolated workspaces + dev/staging/prod stages	—	02 · 07
A.8.32	Change management	✓ Provided	Reversible blue-green promotion path	Change approval workflow	07
A.5.30	ICT readiness for business continuity	✓ Provided	DR slot + rehearsed, recorded recovery tests	BCP/DR plan & RTO/RPO targets	10

SOC 2 (Trust Services Criteria)

The common-criteria and availability TSCs Bailey supports as a service component. Your audit still covers the organizational criteria (CC1–CC5), risk assessment and vendor management.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
CC6.1	Logical access security	✓ Provided	Device-trust gate fronting every endpoint	Access policy & ownership	01
CC6.2 / CC6.3	Access provisioning & removal	✓ Provided	Central role + device grant/revoke	Timely de-provisioning process	13
CC6.6	Boundary protection	✓ Provided	Default-deny egress allow-list	Network perimeter design	12
CC6.7	Data in transit protection	▸ Partial	TLS-terminating ingress	Cert lifecycle, data-at-rest encryption	01
CC7.1	Vulnerability detection	✓ Provided	SBOM + CVE scan on the image that ships	Remediation tracking	06
CC7.2	System monitoring	▸ Partial	Container health + event history	Alerting & on-call	11
CC8.1	Change management	✓ Provided	Promotion pipeline + immutable deploy history	Change authorization	07 · 11
A1.2	Backup & environmental protection	✓ Provided	Snapshots + standby DR slot	Backup off-platform	09 · 10
A1.3	Recovery testing	✓ Provided	Rehearse-into-DR + recorded recovery tests	Test cadence sign-off	10

DORA (Regulation (EU) 2022/2554)

The ICT risk-management articles Bailey operationalizes for financial entities. Governance, incident reporting to authorities, and third-party registers remain your obligation.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
Art. 8	Identification of ICT risk	✓ Provided	Pre-deploy supply-chain / CVE identification	Risk register & classification	06
Art. 9(3)	Strong authentication & protection	✓ Provided	Device-trust gate	Identity governance	01
Art. 9	Protection & prevention (change impact)	✓ Provided	Zero-downtime blue-green change path	Segregation policy	07
Art. 10	Detection of anomalous activity	▸ Partial	Health + deployment/event history	Detection thresholds & alerting	11
Art. 11	Response & recovery	✓ Provided	One-cutover DR swap, no data move	Crisis-management plan	10
Art. 12	Backup, restoration & testing	✓ Provided	Snapshots + rehearsed DR restores	RTO/RPO & offsite policy	09 · 10
Art. 13	Learning & evolving	✓ Provided	Complete, inspectable deploy audit trail	Post-incident review process	11
Art. 24–26	Resilience testing programme	▸ Partial	Runnable requirement tests + DR rehearsals	TLPT for significant entities	04 · 10

NIS2 (Directive (EU) 2022/2555)

The Article 21(2) cybersecurity-risk-management measures Bailey delivers technically. Governance, training and incident notification to your CSIRT stay with you.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
Art. 21(2)(a)	Risk analysis & network security	▸ Partial	Default-deny egress with reviewed exceptions	Risk-analysis methodology	12
Art. 21(2)(b)	Incident handling	▸ Partial	Reconstruct events from the audit trail	Incident response & notification	11
Art. 21(2)(c)	Business continuity & backups	✓ Provided	Backups + zero-downtime DR swap	BCP & crisis comms	09 · 10
Art. 21(2)(d)	Supply-chain security	✓ Provided	SBOM + CVE visibility per image	Supplier assessment	06
Art. 21(2)(e)	Secure development & vuln handling	✓ Provided	Pre-deploy checks + versioned waivers	SDLC policy	05
Art. 21(2)(h)	Cryptography	✓ Provided	Secret handling + TLS at the edge	Crypto policy	08
Art. 21(2)(i)	Access control & asset management	✓ Provided	Roles + workspace/endpoint inventory	Asset ownership	02 · 13
Art. 21(2)(j)	Multi-factor authentication	✓ Provided	Hardware-bound device trust	Enrolment policy	01

GDPR (Regulation (EU) 2016/679)

The security-of-processing and accountability articles Bailey supports. Lawful basis, data-subject rights, DPIAs and breach notification remain controller obligations.

CONTROL	WHAT IT REQUIRES	STATUS	BAILEY GIVES YOU	YOUR PART	CH.
Art. 30	Records of processing activities	✓ Provided	Per-egress data-processing record, auto-maintained	Controller-level register	12
Art. 28	Processor obligations / DPAs	✓ Provided	DPA stored before egress is allowed	Contract terms & due diligence	12
Art. 32	Security of processing	✓ Provided	Access control, secrets, backup & resilience	Risk-based measures & review	08 · 09 · 10
Art. 5(1)(f)	Integrity & confidentiality	✓ Provided	Gated access + default-deny egress	Data-handling policy	01 · 12
Art. 33	Breach notification	▸ Partial	Audit trail to reconstruct what happened	72-hour notification process	11